REQUIREMENTS – S-Bank

Dokument określa wymagania projektu S-Bank.

1. Cel aplikacji

S-Bank to aplikacja bankowa działająca w przeglądarce oraz na urządzeniach mobilnych (Android, iOS). Pozwala użytkownikowi założyć konto, bezpiecznie się zalogować, sprawdzić saldo i historię operacji, wykonać przelew (tradycyjny lub za pomocą kodu QR) oraz przeliczyć waluty według aktualnych kursów NBP.

Pytanie	Odpowiedź
Jaki problem rozwiązuje?	Zapewnia szybkie i wygodne zarządzanie środkami finansowymi z telefonu i komputera, przy jednoczesnej ochronie przed najczęstszymi atakami na bankowość elektroniczną (phishing, przejęcie sesji, manipulacja parametrami transakcji).
Kto będzie z niej korzystał?	Klienci indywidualni banku, pracownicy obsługi klienta (wsparcie techniczne) oraz administratorzy systemu.
Dlaczego jest potrzebna?	Demonstruje w praktyce bezpieczny proces wytwarzania oprogramowania (**DevSecOps**) oraz integrację gotowych, sprawdzonych mechanizmów ochrony: standardu OIDC z PKCE, kluczy dostępu (Passkeys), szyfrowania TLS i kontroli dostępu po stronie serwera.
Jaką podstawową czynność umożliwia?	Bezpieczne wykonanie przelewu z własnego rachunku z weryfikacją salda oraz limitu dziennego na serwerze i dodatkowym potwierdzeniem kluczem dostępu dla wyższych kwot.

2. Rodzaje użytkowników i ich możliwości

Użytkownik	Możliwości	Ograniczenia
Gość (niezalogowany)	Rejestracja nowego konta, przeglądanie aktualnych kursów walut NBP oraz korzystanie z kalkulatora walutowego.	Brak dostępu do jakichkolwiek danych klientów i funkcji transakcyjnych; nałożony limit liczby zapytań (Rate Limiting).
Klient (`CLIENT`)	Logowanie (hasło lub Passkey), podgląd własnego rachunku i historii operacji, zlecanie przelewów, generowanie i skanowanie kodów QR do płatności, zarządzanie swoimi kluczami dostępu.	Widzi i modyfikuje wyłącznie własne dane; przelew od 1 000 zł wymaga dodatkowego potwierdzenia kluczem dostępu; nie może samodzielnie zmienić narzuconego limitu.
Obsługa klienta (`SUPPORT`)	Wyszukiwanie klientów, podgląd ich rachunków oraz historii transakcji w trybie tylko do odczytu w celu pomocy technicznej.	Brak możliwości zlecania przelewów, edycji sald, zmiany ról oraz modyfikacji limitów; każde wyświetlenie danych jest logowane.

Użytkownik	Możliwości	Ograniczenia
Administrator (`ADMIN`)	Zarządzanie kontami użytkowników i rolami, blokowanie i odblokowywanie rachunków, zmiana dziennych limitów transakcyjnych, odczyt dziennika zdarzeń (audytu).	Nie może zlecać przelewów w imieniu klientów, ręcznie modyfikować salda rachunków ani usuwać wpisów z dziennika audytowego.

3. Wymagania funkcjonalne

ID	Wymaganie	Użytkownik
FR-01	**Rejestracja konta.** Gość zakłada konto, podając podstawowe dane osobowe, adres e-mail i hasło. System automatycznie otwiera dla nowego użytkownika rachunek demonstracyjny z saldem początkowym.	Gość
FR-02	**Logowanie i wylogowanie.** Użytkownik loguje się za pośrednictwem serwera Keycloak przy użyciu hasła lub klucza dostępu (Passkey). Wylogowanie unieważnia sesję w aplikacji oraz na serwerze tożsamości.	Wszyscy
FR-03	**Pulpit klienta.** Po zalogowaniu klient widzi podsumowanie swojego rachunku: aktualne saldo, stopień wykorzystania limitu dziennego oraz listę ostatnich transakcji.	Klient
FR-04	**Historia operacji.** Klient przegląda pełną historię swojego rachunku z możliwością filtrowania operacji (np. po dacie lub typie transakcji: uznania/obciążenia).	Klient
FR-05	**Przelew tradycyjny.** Klient zleca przelew, podając numer rachunku odbiorcy, kwotę i tytuł. System weryfikuje poprawność danych, dostępne środki oraz limit dzienny, a dla kwot od 1 000 zł wymaga dodatkowego potwierdzenia kluczem dostępu (Passkey).	Klient
FR-06	**Płatność kodem QR.** Klient może wygenerować kod QR zawierający dane do przelewu lub zeskanować kod innego użytkownika aparatem telefonu, co po walidacji automatycznie wypełnia formularz przelewu.	Klient
FR-07	**Kursy walut i przelicznik NBP.** Użytkownik (również niezalogowany) widzi aktualne kursy średnie walut pobierane z publicznego API NBP i może przeliczyć wybraną kwotę w PLN na walutę obcą.	Wszyscy
FR-08	**Panel obsługi klienta.** Pracownik wyszukuje klienta i przegląda szczegóły jego rachunku oraz historię operacji w trybie tylko do odczytu.	Obsługa klienta
FR-09	**Panel administratora.** Administrator przegląda listę użytkowników, blokuje lub odblokowuje rachunki, modyfikuje dzienne limity przelewów oraz przegląda dziennik audytowy.	Administrator

4. Wymagania bezpieczeństwa

ID	Wymaganie	Sposób realizacji
SR-01	**Automatyczna analiza kodu i zależności (DevSecOps).** Każda zmiana w repozytorium uruchamia potok CI/CD wykonujący statyczną analizę kodu (SAST) oraz skanowanie bibliotek pod kątem znanych podatności (SCA).	GitHub Actions, CodeQL / Semgrep, Dependabot
SR-02	**Ochrona sekretów i kontenerów (DevSecOps).** Automatyczne wykrywanie przypadkowo umieszczonych w kodzie haseł lub kluczy oraz skanowanie obrazów Docker pod kątem luk bezpieczeństwa. Sekrety przekazywane wyłącznie przez zmienne środowiskowe.	Gitleaks, Trivy, zmienne środowiskowe (`.env`)
SR-03	**Uwierzytelnianie OpenID Connect z PKCE.** Logowanie odbywa się wyłącznie przez zewnętrzny serwer tożsamości; aplikacja kliencka nigdy nie przetwarza haseł użytkowników.	Keycloak, `expo-auth-session`, `expo-web-browser`
SR-04	**Silne uwierzytelnianie (Passkeys i Step-up) oraz ochrona logowania.** Wymuszenie polityki silnych haseł, czasowa blokada konta po serii nieudanych prób (Brute Force) oraz wymóg potwierdzenia kluczem dostępu (WebAuthn) dla przelewów od 1 000 zł.	Wbudowane mechanizmy Keycloak, weryfikacja tokenu JWT w API
SR-05	**Kontrola dostępu po stronie serwera (RBAC i BOLA/IDOR).** Domyślna odmowa dostępu, weryfikacja roli użytkownika z tokenu JWT oraz sprawdzanie właściciela zasobu przy każdym zapytaniu do API.	NestJS Guards, weryfikacja identyfikatora użytkownika
SR-06	**Walidacja danych i spójność transakcji.** Ścisła walidacja typów i kwot na serwerze (odrzucanie nadmiarowych pól), walidacja danych z kodów QR, parametryzowane zapytania do bazy oraz realizacja przelewów w transakcji bazodanowej.	NestJS (`class-validator`), Prisma ORM, transakcje PostgreSQL
SR-07	**Bezpieczne przechowywanie sesji i ochrona urządzenia.** Zapis tokenów w bezpiecznym magazynie sprzętowym urządzenia, krótki czas życia tokenu dostępowego oraz blokada wykonywania zrzutów ekranu na widokach finansowych.	`expo-secure-store`, `expo-local-authentication`, `expo-screen-capture`
SR-08	**Bezpieczeństwo sieciowe i ochrona przed nadużyciami.** Szyfrowanie całej komunikacji (HTTPS / TLS), nagłówki bezpieczeństwa, ograniczenie liczby zapytań (Rate Limiting) oraz bezpieczne odpytywanie API NBP z buforowaniem (cache).	Serwer Caddy (TLS), `helmet`, `@nestjs/throttler`
SR-09	**Dziennik audytowy (Logowanie zdarzeń).** Zapisywanie kluczowych operacji (logowania, zlecone przelewy, podgląd danych przez obsługę, blokady kont i zmiany limitów) w bazie danych, bez rejestrowania haseł i tokenów.	Moduł audytu w NestJS (PostgreSQL) oraz logi Keycloak

5. Model zagrożeń

Kategorie STRIDE: **S** – podszycie się, **T** – manipulacja danymi, **R** – wyparcie się, **I** – ujawnienie informacji, **D** – odmowa usługi, **E** – podniesienie uprawnień.

ID	Zagrożenie	Czego dotyczy	Możliwe konsekwencje	Planowana kontrola / działanie
T-01	**Wyciek sekretów w repozytorium lub użycie podatnej zależności / obrazu Dockera** (I, E)	Repozytorium kodu, pakiety `npm`, obrazy kontenerów, potok CI/CD	Przejęcie dostępu do bazy danych lub zdalne wykonanie kodu przez wykorzystanie znanej luki w zewnętrznej bibliotece.	Przechowywanie sekretów poza repozytorium oraz automatyczne skanowanie przy każdym PR w GitHub Actions (Gitleaks, Dependabot, CodeQL, Trivy).
T-02	**Dostęp do cudzego rachunku przez podmianę identyfikatora w API – BOLA / IDOR** (I, E)	Endpointy API obsługujące rachunki, historię operacji i przelewy	Wyciek danych finansowych innych klientów lub wykonanie przelewu z cudzego rachunku.	Weryfikacja właściciela zasobu oraz roli użytkownika na podstawie tokenu JWT po stronie serwera przy każdym zapytaniu (SR-05).
T-03	**Przejęcie konta przez phishing lub zgadywanie haseł (Credential Stuffing / Brute Force)** (S)	Proces logowania, konto klienta	Nieuprawnione zalogowanie się na konto klienta i wyprowadzenie środków.	Odporne na phishing klucze dostępu (Passkeys), blokada konta po serii nieudanych prób w Keycloak oraz wymóg dodatkowego potwierdzenia od 1 000 zł (SR-03, SR-04).
T-04	**Kradzież tokenów sesji z urządzenia lub podgląd ekranu aplikacji** (S, I)	Tokeny sesyjne (`access` i `refresh token`), widoki z danymi finansowymi	Przejęcie aktywnej sesji użytkownika bez znajomości hasła lub wyciek stanu konta.	Krótki czas życia tokenów, przechowywanie w sprzętowym magazynie (`expo-secure-store`), blokada zrzutów ekranu (`expo-screen-capture`) i nagłówki CSP/Helmet (SR-07, SR-08).
T-05	**Manipulacja parametrami przelewu, wyścig żądań lub złośliwy kod QR** (T, R)	Proces przelewu, saldo rachunku, limit dzienny, skaner kodów QR	Przekroczenie salda lub limitu dziennego, przelanie kwoty ujemnej, wstrzyknięcie spreparowanych danych ze skanera QR.	Ścisła walidacja danych wejściowych (`class-validator`), weryfikacja struktury kodu QR, realizacja przelewu w transakcji bazodanowej oraz zapis w dzienniku audytowym (SR-06, SR-09).
T-06	**Przeciążenie usługi (DoS) lub**	Endpointy logowania i	Niedostępność aplikacji, blokada	Ograniczenie liczby zapytań (`@nestjs/throttler`),

ID	Zagrożenie	Czego dotyczy	Możliwe konsekwencje	Planowana kontrola / działanie
	nadużycie uprawnień przez pracownika (D, I, R)	przelewów, integracja z API NBP, panel obsługi klienta	zapytań do NBP lub nieuzasadnione przeglądanie danych klientów przez pracownika.	buforowanie kursów NBP, uprawnienia obsługi ograniczone wyłącznie do odczytu oraz rejestrowanie każdego podglądu w bazie audytowej (SR-05, SR-08, SR-09).